Vulnerability Assessment: **Brute Force Protection Weakness**
Project 4: Web Application Security Assessment
Week 3: Secure SDLC and Code Review

Vulnerability Information

- **Vulnerability Type:** Authentication Brute Force / Weak Login Protection
- **Risk Level:** High
- **OWASP Category:** A07:2021 – Identification and Authentication Failures
- **Location:** /vulnerabilities/bruteforce/login.php, lines 1–3

Vulnerable Code Analysis

- Low

- Medium

```
// Login failed
sleep( 2 );
$html .= "<pre><br />Username and/or password incorrect.</pre>";
```

- High

```php
// Login failed
sleep( rand( 0, 3 ) );
$html .= "<pre><br />Username and/or password incorrect.</pre>";
```

The system delays failed login attempts by only two seconds (or randomly between 0–3 seconds).
However, there are **no mechanisms** to prevent automated brute force or credential stuffing attacks.
Attackers can continuously send login requests to enumerate valid usernames and crack weak passwords.

Secure Code Screenshot:

```php
session_start();

$ip = $_SERVER['REMOTE_ADDR'];
$attempts = get_login_attempts($ip);

if ($attempts > 5) {
    die("Too many failed attempts. Please try again later.");
}

$query = $db->prepare("SELECT * FROM users WHERE user = ? AND password = ?");
$query->bind_param("ss", $user, $pass);
$query->execute();
$result = $query->get_result();

if ($result->num_rows === 0) {
    record_failed_attempt($ip);
    sleep(rand(2, 5));
    $html .= "<pre><br />Invalid credentials.</pre>";
} else {
    reset_login_attempts($ip);
    $_SESSION['user'] = $user;
    header("Location: dashboard.php");
}
```

Mitigations Applied:

- Implemented rate limiting (maximum 5 failed attempts per IP)
- Added randomized delay to mitigate timing attacks
- Introduced CAPTCHA after multiple failed logins
- Used prepared statements to prevent SQL injection
- Sanitized error messages to prevent information leakage

Recommendations for Development Team

Immediate Actions:

1. **Implement Account Lockout Policy**
    - Temporarily disable account after repeated failed attempts
    - Log and alert suspicious login behavior
2. **Add Rate Limiting & CAPTCHA**
    - Restrict requests per IP using middleware or web server rules
    - Introduce CAPTCHA after 3–5 failed logins
3. **Use Secure Authentication Practices**
    - Enforce strong password requirements and hashing (bcrypt/Argon2)
    - Avoid detailed error messages (e.g., “invalid username”)
4. **Monitoring and Logging**
    - Record login attempts and correlate IP patterns
    - Enable alerts for abnormal authentication activity

References

- **OWASP Cheat Sheet:** Authentication Cheat Sheet
- **CWE Reference:** CWE-307: Improper Restriction of Excessive Authentication Attempts
- **Best Practice:** Implement rate limiting, CAPTCHA, and account lockout mechanisms to mitigate brute force attacks.